

Apache, e il certificato di cui nessuno si fida

Apache che serve in HTTP e in HTTPS, con un certificato che si è firmato da solo. Ogni blocco qui sotto viene da un lab acceso, compreso il momento in cui un client rifiuta quel certificato e la ragione che ne dà.

Comando `qlab run apache-lab`

VM `apache-lab`, porte 80 e 443 inoltrate su porte host dinamiche

Credenziali `labuser` / `labpass`

Esito `qlab test apache-lab` → 6 esercizi, 35 controlli, tutti superati

1. Cosa sta girando

```
Server version: Apache/2.4.52 (Ubuntu)
Server built:   2026-07-06T16:41:46
active
enabled
```

```
root      2242      1 /usr/sbin/apache2 -k start
www-data  5036      2242 /usr/sbin/apache2 -k start
www-data  5037      2242 /usr/sbin/apache2 -k start
```

Un processo `root` e una schiera di figli `www-data`. Il processo `root` esiste per legarsi alle porte 80 e 443 — sotto la 1024, quindi privilegiate — e per rileggere la configurazione; i figli servono le richieste senza privilegi. Lo schema che decide come quei figli sono organizzati Apache lo chiama **MPM**:

```
authz_core_module (shared)
mpm_event_module (shared)
rewrite_module (shared)
ssl_module (shared)
```

`mpm_event` è il default moderno: pochi processi, ciascuno con molti thread, e le connessioni in semplice attesa vengono restituite a un listener invece di tenere occupato un worker. Il vecchio `mpm_prefork` — un processo per connessione — è ancora quello che si ottiene quando un modulo non è thread-safe, che in pratica significa il classico `mod_php`.

Il resto di quell'elenco è l'altro tratto distintivo di Apache: quasi tutto è un modulo da accendere. `ssl_module` è il motivo per cui la 443 risponde, e `a2enmod` / `a2dismod` sono l'interruttore.

```
LISTEN 0      511      *:80  *:*
```

```
LISTEN 0      511      *:443 *:*
```

2. I siti

```
total 0
lrwxrwxrwx 1 root root 35 Sep 14 09:39 default-ssl.conf -> ../sites-available/default-ssl.conf
lrwxrwxrwx 1 root root 31 Sep 14 09:39 default.conf -> ../sites-available/default.conf

000-default.conf
default-ssl.conf
default.conf
```

Apache separa *disponibile* da *attivo* come fa nginx, con `a2ensite` e `a2dissite` a gestire i collegamenti. Qui sono accesi sia il sito in chiaro sia quello TLS.

```
<VirtualHost *:443>
  ServerName localhost
  DocumentRoot /var/www/html
  SSLEngine on
  SSLCertificateFile /etc/ssl/certs/apache-selfsigned.crt
  SSLCertificateKeyFile /etc/ssl/private/apache-selfsigned.key
  <Directory /var/www/html>
    Options Indexes FollowSymLinks
    AllowOverride All
    Require all granted
  </Directory>
</VirtualHost>
```

3. Il certificato, e perché un client lo rifiuta

```
certificate: /etc/ssl/certs/apache-selfsigned.crt
subject=CN = localhost, O = apache-lab, C = US
issuer=CN = localhost, O = apache-lab, C = US
notBefore=Sep 14 09:39:27 2026 GMT
notAfter=Sep 14 09:39:27 2027 GMT
```

Le due righe vanno lette insieme: **subject e issuer coincidono**. È la definizione di certificato autofirmato — garantisce per sé stesso, e non c'è sopra di lui nessuna autorità di cui il client già si fidi.

La conseguenza non è sottile:

```
$ curl -I http://localhost/
HTTP/1.1 200 OK
Date: Mon, 14 Sep 2026 09:40:56 GMT
Server: Apache/2.4.52 (Ubuntu)
Last-Modified: Mon, 14 Sep 2026 09:40:45 GMT
ETag: "15-65b6e3a7a452b"

$ curl -Ik https://localhost/
HTTP/1.1 200 OK
Date: Mon, 14 Sep 2026 09:40:56 GMT
Server: Apache/2.4.52 (Ubuntu)
Last-Modified: Mon, 14 Sep 2026 09:40:45 GMT
ETag: "15-65b6e3a7a452b"

$ curl -I https://localhost/ (no -k, so the chain is verified)
curl: (60) SSL certificate problem: self-signed certificate
More details here: https://curl.se/docs/sslcerts.html

curl failed to verify the legitimacy of the server and therefore could not
```

La stessa pagina in HTTP, in HTTPS con `-k`, e in HTTPS senza. `-k` significa «non verificare»; senza, il client controlla la catena, la trova terminata in un certificato per cui nessuno ha garantito, e rifiuta prima ancora di mandare la richiesta.

Non è un certificato rotto

La cifratura è esattamente altrettanto robusta nei due casi. Quello che manca è l'**identità**: un terzo che afferma che questo server è chi dice di essere. Un certificato autofirmato è del tutto appropriato dentro un laboratorio; su internet è l'aspetto che ha un attacco di intercettazione, ed è per questo che i client lo rifiutano in modo rumoroso.

4. Apache controlla la propria configurazione

```
AH00558: apache2: Could not reliably determine the server's fully qualified domain name, using
fec0::5054:ff:fe12:3456. Set the 'ServerName' directive globally to suppress this message
Syntax OK
```

`Syntax OK` è la risposta che si vuole prima di un reload. L'avviso sopra merita di essere letto invece che ignorato: senza un `ServerName` globale, Apache si indovina un nome a partire dagli indirizzi della macchina. Funziona lo stesso, ma qualunque comportamento che dipenda dal nome del server — i redirect che genera, la scelta del virtual host — poggia allora su un'ipotesi.

```
[Mon Sep 14 09:40:53.682319 2026] [ssl:warn] [pid 2242:tid 140274110928768] AH01906: localhost:443:0
server certificate is a CA certificate (BasicConstraints: CA == TRUE !?)
[Mon Sep 14 09:40:53.682412 2026] [mpm_event:notice] [pid 2242:tid 140274110928768] AH00489: Apache/
2.4.52 (Ubuntu) OpenSSL/3.0.2 configured -- resuming normal operations
[Mon Sep 14 09:40:53.682417 2026] [core:notice] [pid 2242:tid 140274110928768] AH00094: Command line: '/
usr/sbin/apache2'
```

Due log, e la divisione conta: `access.log` è una riga per richiesta, `error.log` è dove Apache si spiega. Quando un sito restituisce 500, la riga utile non è quasi mai nel primo file.

5. Verifica

```
Exercise 1: All 8 checks passed
Exercise 2: All 6 checks passed
Exercise 3: All 8 checks passed
Exercise 4: All 3 checks passed
Exercise 5: All 5 checks passed
Exercise 6: All 5 checks passed
Exercises run:      6
Exercises passed:   6
Exercises failed:   0
Exercises skipped:  0
All exercises passed!
```

6. Cosa portarsi via

- L'MPM decide il modello di concorrenza. `event` di default; `prefork` quando un modulo non è thread-safe.
- Apache è fatto di moduli: se manca una funzione, probabilmente il modulo è solo spento. `a2enmod`, poi reload.

- Autofirmato significa subject uguale a issuer. Il traffico resta cifrato; quello che manca è un terzo che garantisca l'identità.
- `-k` in curl e «procedi comunque» in un browser sono la stessa decisione: saltare la verifica. Conviene sapere quando la si sta prendendo.
- Impostate `ServerName` globalmente, o Apache se ne indovinerà uno.
- `access.log` per cosa è stato chiesto, `error.log` per perché è andata male.

`guide.md` del plugin porta gli esercizi: emettere il certificato, i virtual host, `.htaccess` e il controllo d'accesso, e la lettura dei log.